Teknisk specifikation — CVmatchen

Version: 2026-06-17 Författare: Oliver Pettersson, PathfinderAI (enskild firma) Avsedd för: Arbetsmarknadsförvaltningen Helsingborg + tekniska/IT-säkerhetsansvariga

---

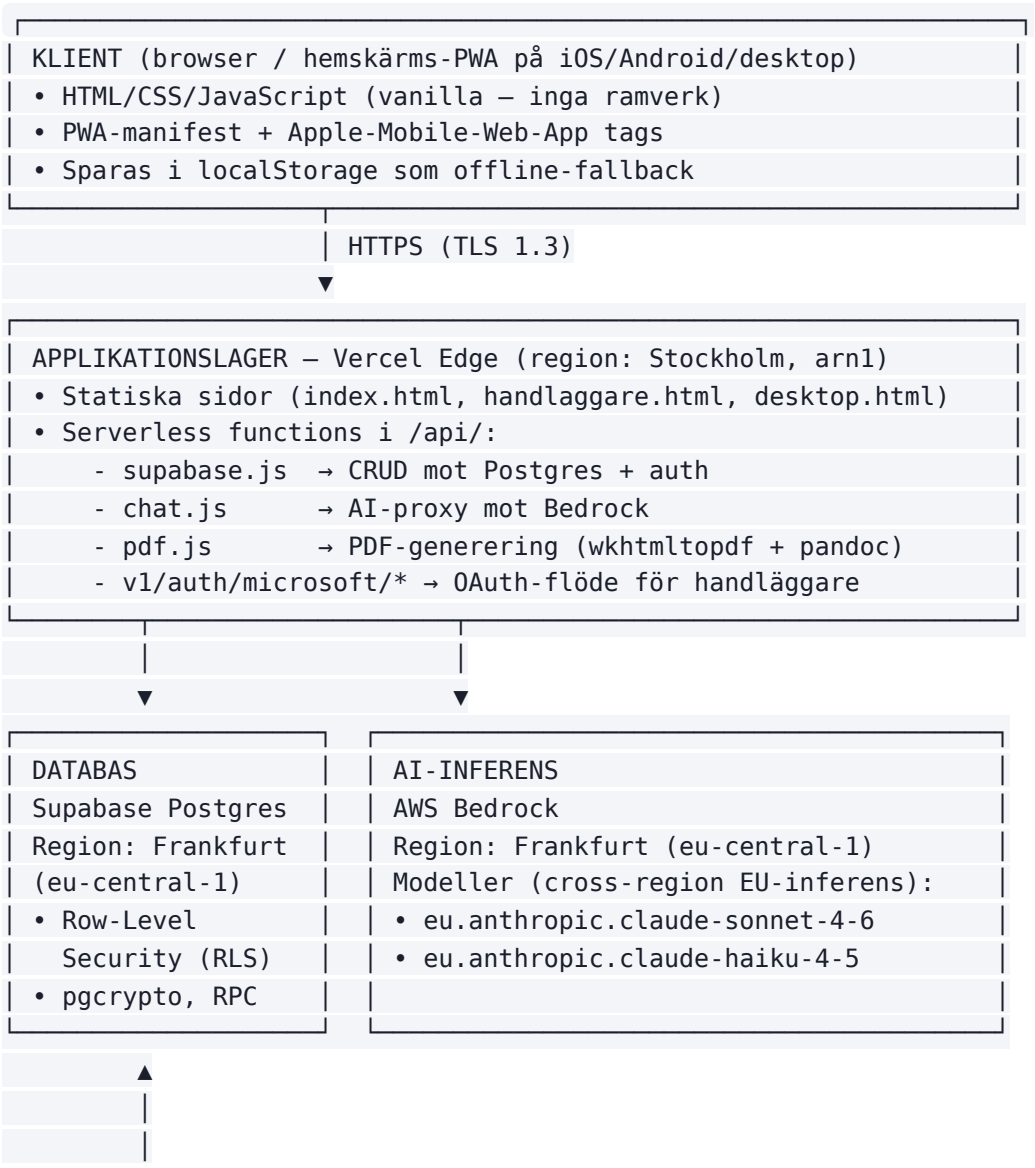
1. Översikt

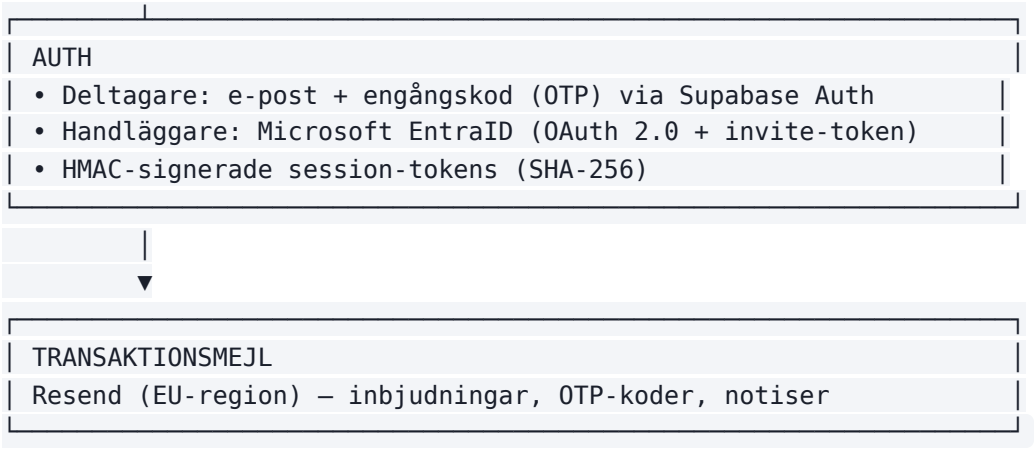
CVmatchen är en webbaserad SaaS-tjänst som hjälper arbetssökande att skapa CV, matcha mot lediga tjänster och få handledning från arbetsmarknadshandläggare. Tjänsten kör som **Progressive Web App (PWA)** — fungerar i webbläsare på mobil/desktop och kan installeras på hemskärm utan App Store-distribution.

Hela teknikstacken är inom EU/EES för GDPR-efterlevnad.

---

2. Arkitektur — helhet





---

3. Klient-sidan (frontend)

Filer

- `index.html` — mobilappen (deltagare). PWA-aktiverad.
- `desktop.html` — desktop-vyn för deltagare.
- `handlaggare.html` — admin-panel för handläggare och kommunadministratörer.
- `intervju.js` + `intervju.css` — separat modul för AI-intervjuträning.
- `training-modules.js` — gemensam datafil för träningsinnehåll.

Designprinciper

- **Vanilla JavaScript** — inga ramverk (React/Vue/Angular). Snabbare laddning, mindre angreppsyta, längre livslängd utan beroendekedjor.
- **Systemfont-stack** — inga Google Fonts. GDPR-säkrare (ingen tracking).
- **CSP (Content Security Policy)** — strikt headers från Vercel.
- **XSS-skydd** — all användardata escapas via dedicerade `escapeHtml`-funktioner.

Offline & PWA

- `manifest.json` med standalone display + app-ikoner.
- localStorage cachar CV-data, träningsprogress och tasks som fallback om nätverket går ner mitt i ett pass.
- Synkar mot Supabase så fort nätet är tillbaka.

Säkerhetstester (juni 2026)

- DOM-XSS-revision (handlaggare.html, index.html) — fixad.
- Host-header-injection (OAuth-callback) — fixad.
- Input-sanering på alla URL-parametrar — implementerad.

---

4. Applikationslagret (Vercel Serverless)

Region: Stockholm (arn1)

Vercels region `arn1` ligger i AWS Stockholm-datacenter.

Besöksstatistik

Vercel Web Analytics är aktiverat — cookiefri och anonymiserad sidvisningsstatistik. Scriptet laddas från samma origin (`/_vercel/insights/script.js`), vilket gör att projektets CSP täcker det utan undantag. Ingen koppling till deltagarkonton.

Funktioner

`/api/supabase.js`

Central CRUD-endpoint. Action-baserad — frontend skickar `{action: "..."}` i POST-body och får tillbaka JSON. Exempel-actions:

- **Auth**: `send_otp` , `verify_otp` , `get_user`
- **Deltagare**: `save_cv` , `save_progress` , `my_tasks` , `ensure_participant`
- **Handläggare**: `admin_list_users` , `admin_get_user` , `assign_task` , `admin_resolve_participant_by_email` , `delete_user`
- **GDPR**: `save_ai_consent` , `request_data_export`

Alla admin-actions kör genom `requireAdmin()` som: 1. HMAC-verifierar handläggarens session-token (timingsafeEqual mot `MICROSOFT_CLIENT_SECRET`). 2. Slår upp aktuell admin-rad i `admins` -tabellen för färska behörigheter. 3. Kontrollerar att begärd kommun/enhet/användare ligger inom adminens tenant (multi-tenant-isolation). 4. Loggar nekade försök till `admin_activity_log` .

`/api/chat.js`

Proxy mot AWS Bedrock. Frontend skickar Claude-format, backend mappar till Bedrock EU-modell-ID:n och vidarebefordrar. Inga prompts loggas permanent (endast Vercels rolling request log).

Mappning:

```
const BEDROCK_EU_MODELS = {
  'claude-sonnet-4-6':          'eu.anthropic.claude-sonnet-4-6',
  'claude-haiku-4-5-20251001':  'eu.anthropic.claude-haiku-4-5-20251001-v1:0'
};
```

`/api/pdf.js`

Genererar PDF via headless Chromium (`puppeteer-core` + `@sparticuz/chromium`). Anropas från CV-export och rapport-export i admin-panelen.

`/api/v1/auth/microsoft/callback.js`

OAuth-callback för handläggare. Validerar: - CSRF-skydd via state-parameter - E-post matchar inbjuden admin-rad - Förstagångsanvändare måste presentera invite-token - Skapar HMAC-signerad session-token (giltig 24h)

---

5. Databas (Supabase / PostgreSQL 17)

Region: Frankfurt (eu-central-1)

Tabellöversikt (förenklat)

- `auth.users` (Supabase Auth) — alla användare med UUID
- `user_assignments` — kopplar deltagare till kommun/enhet/handläggare
- `cvs` — CV-data per user (JSON-fält `data` , soft-version)

- `tasks` — tilldelade uppgifter (status, deadline, verify_field)
- `task_sessions` — tidsstämplade pass när deltagare jobbar på uppgift
- `ovning_progress` — progress per träningsmodul
- `job_diary` — sökta arbeten + status
- `saved_cvs` — sparade matchade CV-versioner
- `interview_sessions` + `interview_messages` — intervjuträning
- `admins` — handläggare/admin-konton (role, kommun_id, enhet_id)
- `kommuner`, `enheter` — multi-tenant-strukturen
- `user_invite`, `user_invite_tokens` — inbjudningsflödet
- `admin_audit`, `admin_activity_log` — säkerhetslogg
- `ai_consent` — GDPR-samtycke för AI-bearbetning

Säkerhet

- **Row-Level Security (RLS)** aktivt på alla tabeller med personuppgifter. Deltagare ser bara sin egen data. Handläggare ser endast deltagare inom sin kommun/enhet.
- **Service role-nyckel** används endast i serverless functions (aldrig i klienten) och bara där admin-behörighet redan verifierats.
- **HMAC-signerade tokens** för admin-sessioner — inte långlivade JWT:s i klienttillgänglig localStorage.

Backup

Supabase Pro tar dagliga backuper med 7 dagars retention. Point-in-time recovery upp till 7 dagar bakåt.

---

6. AI-lager (AWS Bedrock)

Region: Frankfurt (eu-central-1)

Cross-region inference: EU-only

Använder Anthropics Claude-modeller via Bedrock. Modell-ID:n med prefix `eu.anthropic.*` garanterar att inferens stannar inom EU-zonen — ingen trafik till Anthropics egna API:er i USA.

Modeller i drift

Användning	Modell	Skäl
Intervjuträning	claude-sonnet-4-6	Bra nyanserade följdfrågor
CV-AI / matchning	claude-haiku-4-5-20251001	Snabb + billig för många anrop
Matchningsverktyg	claude-sonnet-4-6	Strängare rangordning

Autentisering mot Bedrock

Bearer-token (`AWS_BEARER_TOKEN_BEDROCK`) lagrad som krypterad miljövariabel i Vercel. Roteras kvartalsvis.

Kostnadsbild

~5–15 kr/deltagare/månad vid aktiv användning. Försumbar jämfört med human-handläggar-timme.

---

7. Auth-flöden

Deltagare (mobil/desktop)

1. Anger e-post på inloggningsskärmen.
2. Supabase Auth skickar engångskod (OTP) via mejl (Resend EU).
3. Användaren anger koden i appen.
4. Supabase returnerar JWT (access_token) som lagras i localStorage.
5. JWT skickas med varje API-anrop och valideras serverside via `auth.users`-uppslag.

Handläggare/admin (handlaggare.html)

1. Användaren klickar "Logga in med Microsoft".
2. OAuth-flow mot Microsoft EntraID (login.microsoftonline.com).
3. Callback verifierar att e-posten finns i `admins`-tabellen.
4. Förstagångsanvändare måste presentera invite-token från sin inbjudningslänk.
5. Server skapar HMAC-signerad session-token (24h giltighet).
6. Token förnyas via `/api/v1/auth/refresh` när som helst inom giltigheten.

Inbjudningar (handläggare → deltagare)

1. Admin skapar invite via `create_invite`-action.
2. Token (hex, 32 tecken) sparas i `user_invite_tokens`.
3. Resend skickar mejl med personlig länk.
4. Deltagaren loggar in med OTP → invite-token konsumeras automatiskt och kommun/enhet kopplas på via `user_assignments`.

---

8. GDPR & datasuveränitet

Var lagras data?

Datatyp	Plats	Region
Statiska sidor	Vercel CDN	Stockholm (EU)
Serverless logik	Vercel Functions	Stockholm (EU)
Användardata	Supabase Postgres	Frankfurt (EU)
AI-inferens	AWS Bedrock	Frankfurt (EU)
Transaktionsmejl	Resend	EU
Backup	Supabase managed	EU

Ingen data lämnar EU/EES. Ingen tredjelandsöverföring → ingen SCC-/TIA- process behövs.

Personuppgifter som behandlas

- Namn, e-post, telefon (deltagaren själv anger)
- CV-data (anställningshistorik, utbildning, kompetenser)
- Aktivitetsdata (öppnade lektioner, sökta arbeten, tilldelade uppgifter)
- AI-konversationer (intervjuträning) — pseudonymiserade

- Inga särskilda kategorier av personuppgifter (hälsa, etnicitet, etc.)

Rättslig grund

- **Allmänt intresse** (GDPR art. 6.1.e) — kommunal arbetsmarknadsverksamhet
- **Samtycke** (art. 6.1.a) — separat samtycke för AI-bearbetning av CV (versionerat, kan återkallas)

Användarrättigheter

- Tillgång till sin data via "Exportera mina data" i profil-menyn
- Radering via "Radera mitt konto" — kaskaderar genom alla tabeller
- Rättelse — användaren redigerar själv
- Begränsning — pausa kontot via handläggare

---

9. Säkerhetsåtgärder

Tekniska

- TLS 1.3 enforced (HSTS preload)
- CSP, X-Frame-Options: SAMEORIGIN, X-Content-Type-Options: nosniff
- HMAC-SHA256 för session-tokens (constant-time-jämförelse)
- Bcrypt + Supabase Auth-policies för lösenord (deltagare använder bara OTP)
- Rate-limiting på auth-endpoints (planerat — bör utökas inför skarp drift)
- Service role-nycklar aldrig i klient
- Sentry för error-tracking (EU-region)

Organisatoriska

- Singel-utvecklare i nuläget (Oliver Pettersson) — alla commits signerade
- Github-repo privat, branch-protection på `main`
- Vercel-deploy från `main` (automatisk)
- Inga produktionsdata i utvecklingsmiljö

Pågående säkerhetsbacklog (sept 2026)

- Rate-limiting på admin-endpoints
- Audit-log-fyllning för alla mutationer
- Penetrationstest av extern part (planerat Q3)
- DPIA (Data Protection Impact Assessment) — krävs innan skarp drift

---

10. Deployment & CI/CD

- **Hosting**: Vercel Pro (PathfinderAI:s konto)
- **Branch**: `main` → automatisk deploy till `cvmatchen.com`
- **Rollback**: instant via Vercel-dashboarden (förra deploymentens URL kvar)
- **Miljövariabler**: krypterade i Vercel (Supabase-nycklar, Bedrock-token, Microsoft-secret, Resend-API-key)

---

11. Skalbarhet

Nuvarande arkitektur klarar **5 000+ samtidiga användare** utan kodändringar (Supabase Pro + Vercel Pro). För större volymer: - Supabase Pro → Team-plan (multi-region read replica) - Vercel Pro → Enterprise (egen edge-region) - Bedrock — pay-per-token, ingen kapacitetstak

För Helsingborgs pilot (~10 deltagare, 2 handläggare) finns 100x marginal.

---

12. Vidareutveckling — färdplan

Q3 2026 (efter pilot-start): - WCAG 2.1 AA-revision + tillgänglighetsutlåtande - Capacitor-wrap → App Store + Google Play (push-notiser) - Källredovisning per träningsmodul

Q4 2026: - Penetrationstest - DPIA - Visionsfonden-ansökan (september)

2027: - Integration mot Lifecare/ProCapita-API:er om kommunen vill - Multi-kommun-utrullning

---

Kontakt

Oliver Pettersson — Studie- och yrkesvägledare, grundare PathfinderAI oliver.pettersson2@gmail.com

För säkerhets-/IT-frågor: samma mejl, märk ärendet "TEKNISK".